



OpenClaw, Patch the Planet

Security Assessment (Summary Report)

September 15, 2026

Prepared for:

Josh Avant

OpenClaw Foundation

Prepared by: **Samuel Judson and Lucas Bourtole**

Table of Contents

Table of Contents	1
Project Summary	2
Project Targets	3
Executive Summary	4
Summary of Advisory Submissions	6
Notices and Remarks	9

Project Summary

Contact Information

The following project manager was associated with this project:

Jenelle Lareche, Project Manager
jenelle.lareche@trailofbits.com

The following engineering director was associated with this project:

Tjaden Hess, Engineering Director, ML Security
tjaden.hess@trailofbits.com

The following consultants were associated with this project:

Samuel Judson , Consultant samuel.judson@trailofbits.com	Lucas Bourtole , Consultant lucas.bourtole@trailofbits.com
---	--

Project Timeline

The significant events and milestones of the project are listed below.

Date	Event
August 6, 2026	Pre-project kickoff call
August 26, 2026	Delivery of report draft
August 26, 2026	Report readout meeting
September 15, 2026	Delivery of final summary report

Project Targets

The engagement involved reviewing and testing the following target.

OpenClaw

Repository openc1aw

Commit baf85e6868e67aebd12ef0e7b77774061fc9db2f

Version v2026.8.1-beta.2

Executive Summary

Engagement Overview

OpenAI engaged Trail of Bits to review the security of OpenClaw, a local-first agent platform that exposes messaging, browser, tool, MCP, automation, memory, and Gateway surfaces to model-driven workflows. The assessment focused on the security boundaries that OpenClaw documents in SECURITY.md, especially those related to authentication, tool policy, approvals, sandboxing, browser and workspace isolation, requester-scoped controls, and the handling of attacker-controlled content across long-lived agent state. This review is part of OpenAI's Patch the Planet program.

A team of two consultants conducted the review from August 10 through August 21, 2026, for a total of three engineer-weeks of effort. With full access to source code and documentation, we performed static and dynamic testing of OpenClaw, using exclusively AI-driven processes as part of OpenAI's Patch the Planet program. We used OpenAI's GPT-5.5-Cyber preview to assist us during the review.

Observations and Impact

The audit produced 212 confirmed granular findings. Those findings were aggregated into larger disclosure units. Many findings were indeed variants of the same underlying boundary failure; several were already fixed in newer main snapshots before reaching stable releases, and many others were later determined to fall outside the current OpenClaw threat model after clarification from the maintainer.

The final disclosure set is best understood as 27 advisory submissions, one architectural submission, and three hardening submissions:

- Two high-severity, 16 medium-severity, and six low-severity GHSA submissions covering boundary-valid findings that remained present on the current main branch
- Three informational GHSA submissions corresponding to defense-in-depth findings
- One informational GHSA submission consolidating the architectural implications of the outside-scope finding space
- Three hardening PRs that did not receive GHSA listings

The most important product-level conclusion is that OpenClaw's current threat model is coherent only under a stronger assumption than "one trusted operator." In practice, OpenClaw assumes one trusted operator and trusted inputs: any web page, document, transcript, message, tool result, callback, or memory visible to the model may influence any non-owner-only authority already granted to the agent, unless a separate hard boundary prevents it.

That assumption is materially narrower than typical web-connected or organization-connected agent deployments. The outside-scope findings repeatedly showed that origin, provenance, and delegation are not consistently treated as first-class policy inputs, even though those properties become critical once an agent can access browsers, credentials, documents, memory, automation, and mixed-trust messaging.

Recommendations

Trail of Bits recommends that OpenClaw continue addressing the submitted boundary-valid GHSA's individually while also treating the informational threat-model GHSA as an architectural decision point.

If maintainers want to preserve the current threat model, `SECURITY.md` should state plainly that arbitrary external inputs are incompatible with powerful agent authority unless all reachable content is intentionally trusted.

If maintainers want to support practical web-connected and shared-agent deployments, OpenClaw should add a stricter mode in which requester identity, content origin, provenance labels, delegation scope, and sink policy are first-class security inputs rather than advisory metadata.

Summary of Advisory Submissions

High-Severity GHSA Submissions

- GHSA-m969-2g5c-fhwp: System Agent config_get Redaction Bypass. **Closed as not applicable, as the issue was fixed before reporting.**
- GHSA-9m4p-cqp4-jppq: WhatsApp Login Non-Owner Re-Exposure

Medium-Severity GHSA Submissions

- GHSA-5fwv-r rvp-8xvr: Session Filename Generation Can Execute Tools Denied To The Requesting User
- GHSA-62qm-6f j j-6g23: Restricted User Input Can Reach An Unattended Agent With Write And Command Tools
- GHSA-33m5-gr 8m-x3vw: Limited Voice Session Credentials Can Launch An Agent With File And Command Tools
- GHSA-r r xp-5mx8-mvhh: Classic Inbound Voice Calls Inherit The Agent's Full Tool Authority
- GHSA-qg j 5-6x35-9g6f: Config Redaction Exposes Offline Verifiers For Weak Gateway Passwords
- GHSA-h2qg-f xpv-82v6: Model Tools Can Use Credentials From A Disabled Feishu Default Account
- GHSA-m848-f r 8q-4vp8: Generic Node Invocation Bypasses Per Agent MCP Tool Denies
- GHSA-w5x7-c87m-3 j pc: Requester Scoped Read Denies Do Not Block Outbound Local Attachments
- GHSA-fphf-69cp-h5xw: Telegram Sends Unvalidated Host Files Hidden Behind A Valid Attachment Alias
- GHSA-5rx7-34fw-64qg: Unicode workspace0n1y Parent Fallback Escape
- GHSA-h7j f-r j j 9-cww2: MCP App Read Authority Revocation Bypass
- GHSA-v7hh-7676-rg67: Slack download-file Scope Fail-Open
- GHSA-3mq7-q27j-mq7q: Exec Approval CWD Drift
- GHSA-7hw8-j xwc-cwg6: Portal Cookie Origin Collision

- GHSA-85g6-c327-vpf2: Beam Isolated-Profile Catalog Bypass
- GHSA-7jfq-rmfm-29wp: File-Transfer Durable Approval Binding Failures

Low-Severity GHSA Submissions

- GHSA-5qfh-c63r-7v7g: Curated Memory Provenance Auto-Injection Bypass
- GHSA-chr6-w4m5-57fv: Existing Agents Can Keep Reading Memory After It Is Disabled
- GHSA-6xpv-wwr5-265h: Truncated Tar Bz2 Listings Bypass Skill Extraction Limits
- GHSA-hgv5-f2r3-6v9r: Matrix Case Folding Lets Distinct Accounts Share Authorization
- GHSA-wjfv-5qch-m5vj: Active Memory Can Recall Data For Requesters Denied Memory Tools
- GHSA-g24w-m94m-59qc: Webhook TaskFlow Child Session Cancellation

Informational GHSA Submissions

- GHSA-ff43-php7-h37v: Incognito Session Authorization Bypass Via Indirect Selectors And Bare Aliases. Reported as a high-severity issue, closed as a defense-in-depth hardening issue after maintainers clarified that same-Gateway incognito/session isolation is not a supported security boundary.
- GHSA-wc97-fpp5-2gjv: Incognito Compat HTTP Session Key Bypass. Reported as a high-severity issue, closed as a defense-in-depth hardening issue after maintainers clarified that compatible HTTP surfaces remain inside the trusted-operator Gateway boundary.
- GHSA-gxf-f-5vv7-cjjj: Conversations List Cross-Agent Account Bridge. Reported as a high-severity issue, closed as a defense-in-depth hardening issue after maintainers noted that no lower-trust actor is able to cross a security boundary in the trusted-operator Gateway model.
- GHSA-2f88-5vh5-3792: Informational: Threat Model Gaps Exposed By Outside-Scope Prompt-Injection And Provenance Findings. Consolidates 189 findings that fall outside the current threat model after maintainer feedback and stricter reassessment. The outside-scope findings are clustered into four recurring root causes:
 - Agent-global authority instead of origin-bound authority: A sender or content source that can steer an agent can often spend the agent's full connector, skill, browser, memory, or host authority.

- Isolation features without an end-to-end security contract: Sessions, incognito views, DM scopes, and context filters look isolating but are treated as routing or UX-only.
- Provenance is not a first-class policy input: Lower-trust content is not tracked with enough precision to constrain sensitive sinks across turns and storage layers.
- Delegation and interaction replay rebind authority: Approvals, suggestions, buttons, links, and goals often inherit the authority of the later resolver rather than the originating principal.
- Three additional PRs were filled, which correspond to informational/hardening findings that did not receive their own GHSA:
 - <https://github.com/openclaw/openclaw/pull/123846>
 - <https://github.com/openclaw/openclaw/pull/123847>
 - <https://github.com/openclaw/openclaw/pull/123848>

Notices and Remarks

Copyright and Distribution

© 2026 by Trail of Bits, Inc.

All rights reserved. Trail of Bits hereby asserts its right to be identified as the creator of this report in the United Kingdom.

Trail of Bits considers this report public information; it is licensed to OpenAI under the terms of the project statement of work and has been made public at OpenAI's request. Material within this report may not be reproduced or distributed in part or in whole without Trail of Bits' express written permission.

The sole canonical source for Trail of Bits publications is the [Trail of Bits Publications page](#). Reports accessed through sources other than that page may have been modified and should not be considered authentic.

Test Coverage Disclaimer

Trail of Bits performed all activities associated with this project in accordance with a statement of work and an agreed-upon project plan.

Security assessment projects are time-boxed and often rely on information provided by a client, its affiliates, or its partners. As a result, the findings documented in this report should not be considered a comprehensive list of security issues, flaws, or defects in the target system or codebase.

Trail of Bits uses automated testing techniques to rapidly test software controls and security properties. These techniques augment our manual security review work, but each has its limitations. For example, a tool may not generate a random edge case that violates a property or may not fully complete its analysis during the allotted time. A project's time and resource constraints also limit their use.